SECURITY AUDIT

hermes-agent-free

Ubuntu 22.04 · Oracle Cloud ARM · audited 19 October 2026, 17:21–17:35 EAT

> **No open door found.** The machine is reachable from the internet on exactly one port — SSH — and that port refuses password logins and root logins, with brute force actively blocked. Every application service, the database and the browser debugger are bound to loopback only. The two weaknesses are both inside the perimeter: passwordless root for the main user, and four SSH keys of which two grant a full shell.

1. What was checked

AREA	METHOD	RESULT
Listening sockets	Full TCP/UDP port list with owning process	1 public port, 20 loopback
SSH authentication	Effective daemon settings and included config files	Keys only, root refused
Brute force	Fail2ban jail state	Active, 38 banned now
Elevation	Sudo rights and group membership	Passwordless root
Key trust	Authorised keys, line by line	4 keys, 2 unrestricted
Patches	Unattended upgrade configuration	Automatic, on
Secret storage	Directory permission path on config	Owner-only
Host firewall	UFW / iptables presence	Not installed

Limits of this audit. Login history and the authentication log were not readable — the command gate refused that read, so no statement here rests on them. Review was configuration and live state; no exploit attempt or vulnerability scan was run against the running services.

2. What is exposed

PORT	SERVICE	BOUND TO	STATE
22	SSH	All interfaces	PUBLIC
3000, 3001	Web UI, uptime monitor	Loopback	CONTAINED
5432	PostgreSQL 14	Loopback	CONTAINED
11434	Ollama	Loopback	CONTAINED
9222	Chrome debugger	Loopback	CONTAINED
8139–8152	JARVIS Live, site, agent API	Loopback	CONTAINED
8644, 8787, 9119, 9422	Hermes gateway, bridge, worker	Loopback	CONTAINED

Public access to the web surfaces is carried by Cloudflare Tunnel, not by an open port — the tunnel makes outbound connections only, which is the correct arrangement.

3. Findings, ranked

1. Passwordless root for the operating user MEDIUM

The account that runs the agent can execute any command as root with no password. Any code that reaches the agent — a tool, a downloaded package, a prompt injection that lands shell access — inherits the whole machine, not just the agent's own files. This is the finding that turns every other small flaw into a serious one.

2. Two of four SSH keys give a full shell MEDIUM

Two keys are correctly pinned to a single command. The other two — one named for the operator's phone terminal, one for the Windows machine — open an unrestricted shell. That is a deliberate convenience, but it means the security of this server now depends on the physical security of those two devices.

3. No host firewall LOW

UFW is not installed. The only thing keeping the looping services private is that each one binds to loopback. A single future service that binds to all interfaces would be published to the internet the moment it starts, with nothing between it and the world.

4. Four packages behind LOW

Chrome, two iSCSI packages and timezone data have updates pending. Automatic security upgrades are enabled and the OpenSSH package is not among them. The iSCSI packages matter least here — the kernel driver is already current, so they are an installer-versus-module mismatch rather than an exposure.

5. SSH brute force is constant but handled LOW

5,401 failed logins have been recorded against the jail, 386 source addresses banned in total, 38 blocked right now. With password authentication disabled these attempts cannot succeed; fail2ban is keeping the log noise down rather than keeping the door shut.

4. Controls that are working

- **Password login disabled** through a cloud image override — keys are the only way in.
- **Root login refused** — direct login as root is impossible even with the right key.
- **Agent configuration is owner-only** — the config directory is mode 700 and every file inside it 600, so no other account on the machine can read the API keys it holds.
- **Database and model server never face the network** — PostgreSQL and Ollama answer on loopback alone.
- **Browser automation isolated** — the debug port is loopback-only, so no remote party can drive the logged-in browser session.

5. If I were to change three things

- **Scope the sudo grant.** Replace blanket passwordless root with an explicit list of the commands the agent actually needs. It costs a handful of additional sudoers lines and removes the single largest multiplier in the risk picture.
- **Pin the two shell keys.** If the phone terminal and the Windows machine only need what they need, restrict them the way the other two already are. If they genuinely need a shell, that is a conscious trade — accept it knowing those two devices are now part of the perimeter.
- **Install a default-deny host firewall.** A firewall that allows SSH and drops everything else changes the failure mode: a future service binding too widely becomes unreachable rather than published. This is prevention against the mistake nobody has made yet.

None of these is urgent. The exposure that would matter — an open database, an internet-facing agent API, password login on SSH — is not present.

Audit performed 19 October 2026 against live host state. Configuration and socket review only; no package scanning or exploitation attempted. Evidence for every figure sits in this document's source run, which is retained on the machine.